

Security Infrastructure Design Document

Organization: World's Finest Widgets, Inc. (fictional)

Prepared by: Syed Saifullah Gillani, Security Consultant

Date: 09/10/2025

This document outlines the recommended security infrastructure, policies, and configurations to protect the operations, data, and assets of World's Finest Widgets, Inc.

Contents

1	Authentication System	2
2	External Website Security (Customer-Facing E-Commerce Site)	2
3	Internal Website Security (Employee Intranet)	2
4	Remote Access Solution (For Engineers)	2
5	Firewall & Basic Rules Recommendations	3
6	Wireless Security	3
7	VLAN Configuration Recommendations	3
8	Laptop Security Configuration	3
9	Application Policy Recommendations	4
10	Security & Privacy Policy Recommendations	4
11	Intrusion Detection/Prevention for Customer Data Systems	4

1 Authentication System

Authentication will be handled centrally by a secure LDAP/Identity Provider (IdP) service, with all authentication encrypted over LDAPS (TLS).

- **Multi-Factor Authentication (MFA):** All employees must use MFA for internal systems, VPN, and administrative accounts.
- **One-Time Passwords (OTP) / Certificates:** Used as a second factor to strengthen login security.
- **Role-Based Access Control (RBAC):** Employees receive only the access necessary for their roles (*principle of least privilege*).
- **Account Lockout & Throttling:** Implemented to prevent brute-force login attempts.

2 External Website Security (Customer-Facing E-Commerce Site)

The customer-facing website will prioritize secure communication and customer privacy.

- Exclusively served over **HTTPS (TLS 1.2+)** with HSTS enabled.
- **Web Application Firewall (WAF):** Protects against SQL injection, XSS, and other application-layer threats.
- **Content Security Policy (CSP):** Prevents execution of unauthorized JavaScript.
- **Secure Payment Handling:** All payment transactions processed by a PCI DSS-compliant third-party provider; no raw card data stored internally.
- **Penetration Testing:** Conducted quarterly to proactively identify vulnerabilities.

3 Internal Website Security (Employee Intranet)

- Internal access secured with **HTTPS (TLS 1.2+)**.
- Restricted to internal VLAN and VPN access for remote employees.
- **RBAC and Logging:** Permissions enforced by roles, with centralized logging in a SIEM.
- Segregated into a dedicated VLAN to reduce attack surface.

4 Remote Access Solution (For Engineers)

Engineers require secure access to internal resources and workstations.

- **VPN Access:** Remote employees connect using a secure VPN (e.g., OpenVPN or WireGuard) with MFA.
- **Reverse Proxy:** Simplifies internal resource access once connected.
- **SSH Key-Based Authentication:** Only SSH keys allowed, passwords disabled.
- **Bastion Host (Jump Server):** Central entry point for administrative access; all sessions logged.
- **Audit Logging:** All VPN and SSH activities recorded in the SIEM.

5 Firewall & Basic Rules Recommendations

The firewall will enforce an implicit deny-all policy, opening only required ports.

Inbound Rules

- HTTP/HTTPS (80/443) for the external website.
- VPN service port (e.g., 1194 or 51820).
- SSH (22) accessible only internally via VPN, never open to the internet.

Outbound Rules

- Allow DNS and HTTPS.
- Block unnecessary or suspicious outbound traffic.

Internal Segmentation

- Firewall ACLs will strictly control inter-VLAN communication.

6 Wireless Security

- **Enterprise Wi-Fi:** WPA3-Enterprise with 802.1X (EAP-TLS) using client certificates.
- **Guest Wi-Fi:** Separate VLAN with internet-only access.
- **Additional Protections:** Hidden SSIDs and MAC randomization to reduce tracking.

7 VLAN Configuration Recommendations

Network segmentation enhances access control and limits breach impact.

- VLAN 10: Employee Workstations
- VLAN 20: Servers (E-commerce, Intranet, Internal Apps)
- VLAN 30: Guest Wi-Fi (Internet Only)
- VLAN 40: Management (Firewall, IDS/IPS, Monitoring)

Access Control: Inter-VLAN routing restricted through firewall rules.

8 Laptop Security Configuration

Laptops will be secured as critical endpoints.

- **Full-Disk Encryption (FDE):** BitLocker (Windows) or FileVault (macOS).
- **Endpoint Protection:** Antivirus and Endpoint Detection & Response (EDR).
- **System Hardening:**
 - Automatic patching enabled.
 - Local administrator accounts disabled.

- USB device control enforced.
- **VPN Auto-Connect:** All remote traffic routed through VPN by default.
- **Mobile Device Management (MDM):** Central enforcement of security policies.

9 Application Policy Recommendations

- **Application Whitelisting:** Only approved applications may run.
- **No Unauthorized Software:** Personal or pirated software prohibited.
- **Patch Management:** Critical patches applied within 30 days; zero-day patches applied immediately.

10 Security & Privacy Policy Recommendations

- **Acceptable Use Policy:** Defines proper use of systems and devices.
- **Data Handling & Privacy:** Policies aligned with PCI DSS and GDPR to minimize PII collection.
- **Access Requests:** Data access must be justified, approved, and time-limited.
- **Prohibited Storage:** Customer data cannot be stored on portable devices unless encrypted.
- **Employee Training:** Annual training covering phishing, device security, and emerging threats.

Password Policy

- Minimum length: 12 characters (prefer passphrases).
- Must include letters, numbers, and special characters.
- Changed every 12 months.
- MFA required for sensitive accounts.

11 Intrusion Detection/Prevention for Customer Data Systems

- **Network IDS (NIDS):** Monitors traffic across VLANs for suspicious activity.
- **Network IPS (NIPS):** Deployed in VLAN containing customer data.
- **Host-Based IDS (HIDS):** Installed on critical servers for file integrity monitoring.
- **SIEM Integration:** Centralized collection of IDS/IPS alerts for incident response.